MASTER PLAN v2.1: GeminiForge documentation workspace (living document)

v1 written 2026-10-21 morning. **v2 rewritten 2026-10-21 after six sourced research passes** (docs/10, 13-18). `[x]` = done and tested, `[~]` = partly, `[ ]` = not started, `[?]` = waiting for the owner. Tags: **Q** = question for the owner (my recommendation given), **D** = decision made, **OWN** = only the owner can do it, **S/M/L** = effort (small: under a day, medium: 1-3 days, large: more), **(docs/N)** = where the evidence is. Facts marked UNVERIFIED in the research docs stay unverified here. Superseded by this file: docs/03-ROADMAP-NEXT.md, docs/ROADMAP.md. Older lists kept for reference: docs/05 (155 ideas), docs/08 (audit).

> **v2.1 (2026-10-22):** audit of the ChatGPT Parts A+B research added (docs/19) and owner decisions D12 (Canvas build dropped), D13 (custom dropdowns stay), D14 (share links are project-wide). Part C security audit (docs/21) and Part E+F operations/email audit (docs/22) added the same day.

> **Budget rule D11: 0 USD.** Anything in older docs that costs money (Anthropic/OpenAI/paid Gemini API, domain, Resend, Supabase/Vercel Pro, OpenRouter credit) is dropped or replaced by a free path.

0. State (v0.7.0)

Live: https://geminiforge-workbench.vercel.app (auto-deploys from `main`). Supabase `plbvgcnyfclillatpowc` (free plan). Tests: qa-ai 152, qa-content 12, prodcheck 101, MCP offline 33, invitation email 9, SQL matrix. Phase 1 and 2 below are done. Checked 2026-10-22: Postgres 17.11, database 15 MB of 500 MB, repo already on Vite 8.3.4 / TypeScript 7.0.2 / React 18.3.1, browser + invite + MCP already use `sb_publishable_/sb_secret_` keys.

1. What the research changed (read this first)

1. **Supabase changes Data API grants on 2026-10-30 (8 days away on 2026-10-22).** New `public` tables will no longer be granted to anon/authenticated/service_role automatically; a migration that creates a table without explicit `GRANT` fails with 42501. Rule from now on: every new table migration contains its GRANTs and RLS in the same file. **Functions too**: Supabase's "Securing your API" page says new functions in `public` are also moving to opt-in (`grant execute` explicitly); what exactly happens to new functions on 10-30 is UNVERIFIED, so grant explicitly either way. (docs/16, docs/19)
2. **Phase order changes.** Verify client compatibility (Claude Code, Cursor, claude.ai, Gemini app) BEFORE building OAuth; header tokens first, path tokens only for the Gemini app, read-only, 24 h by default. (docs/14)
3. **Ask-the-docs must cost 0 (D11, owner 2026-10-21).** The paid Anthropic route from docs/15 is dropped. Free path first: your Google AI Pro Gemini app connected to our MCP (no API key), NotebookLM as a reading aid, and an extractive quote-finder built on Postgres full-text search (verbatim by construction, no model). An in-browser model or a free API tier is optional and decided by research prompt Z1. Key rotation across free accounts stays forbidden (terms). (docs/15, docs/12)
4. **Editor: CodeMirror 6 (Markdown source + preview), not a WYSIWYG editor**; save with a version column and 3-way merge, not a CRDT. (docs/17)
5. **Planning layer: rows are the source of truth, Markdown is rendered; progress is computed, never stored.** (docs/13)
6. **New high-value items from the benchmark**: verified/owner/review-by pages, notification inbox, content-gap list, request-access, share-link hardening. (docs/18)

7. **Survival items on the free plan**: backups do not exist unless we build them (re-verified 2026-10-22 on Supabase's backup page: daily backups only on Pro/Team/Enterprise; a ChatGPT audit claiming otherwise was wrong, docs/19); the project pauses after 7 days of no user database activity (in-database cron may not count); Hobby cron runs once per day. (docs/16)
8. **Corrected assumption**: TOTP two-factor sign-in is free on all Supabase plans (only phone MFA is paid; leaked-password protection is Pro). Earlier notes said "no MFA on free": **Q15**, confirm in the dashboard.
9. **Cut or defer** a long list for a solo owner (section 12).
10. **Audit of the ChatGPT Parts A+B report (docs/19, 2026-10-22):** keep CodeMirror 6, Zustand, hash routing, adjacency list, Postgres full-text search; upgrade to React 19.3.1 after the grants work; do the 10-30 migration first; classify the 28 `SECURITY DEFINER` functions; share links use a `#/s/<secret>` fragment with a hashed secret; native `<dialog>` for true modals; no Biome/Rolldown/Tailwind/ltree/vector.
11. **Audit of the ChatGPT Part C (security/privacy) report (docs/21):** share links become `/share#secret` + explicit click + a server proxy (no anonymous RPC, no share JWT); invite-bound account creation (the app has none today); TOTP + AAL2 inside sensitive RPCs; a real CSP after moving the inline CSS; hardened `api/invite` and `/api/join`; append-only security log; supply-chain rules after the 2025-2026 npm compromises (Shai-Hulud, Axios); full git history checked clean. Two report claims were wrong/unconfirmed: free production deployment protection on Vercel, and the Mammoth 1.12.2/1.12.3 advisories.
12. **Audit of the ChatGPT Part E+F (operations + email) report (docs/22):** keep-alive via two independent daily readers of a one-row table; encrypted nightly dump restored inside the same job, copied to Backblaze B2 and a 14-day artifact; Healthchecks + UptimeRobot; Gmail path kept. Report right on the 1-year pause-restore window (the Supabase MCP docs index is stale at 90 days). Report code has real bugs (weekly test never fires, restore into plain Postgres fails, global npm CLI, `curl | bash`, floating action tags).
13. **Audit of the ChatGPT Parts D+G (accessibility, offline, performance, testing) report (docs/24):** nested lists not trees for the plan, native dialog stays, route-backed tabs, 24 px targets, small visual-regression set now, read-only pinned offline, first-party error/RUM tables. Report defects: ESLint 10 + typescript-eslint cannot work with our TypeScript 7 (use Oxlint + tsc), `eslint-plugin-jsx-a11y` is stale, Vercel's free Speed Insights has no CWV values. Audit of our own code found: partial ARIA tabs, no skip link/route titles/focus, control borders at 1.04-1.62:1, Select `aria-controls` mismatch.
14. **Audit of the ChatGPT Run 6 (AI and MCP) report (docs/25):** primary in-app Q&A = extractive passage finder with exact-offset quote verification; Gemini app + our MCP = owner-accepted consumer-cloud path (no AI Pro requirement stated by Google; US, English, personal account, web only); Claude Free is the second test host (fixed header tokens work); no free API gets private text; golden set fixed at 40 (it summed to 42). Our MCP server already implements 2026-07-28 + legacy; it lacks Origin validation (spec MUST) and its IP hash is reversible; our function logs do store `/dk_...` path tokens (47/47 rows). ChatGPT Plus: the report said not eligible, the owner's screenshot shows an "Add custom MCP server" dialog, so it is eligible there.

PHASE 1: Foundations (DONE)

- [x] 1.1 Reader app, answer engine, notes, backups, labs, Canvas single-file build (DROPPED 2026-10-22, D12)
- [x] 1.2 Supabase sync, runtime content bundle, Realtime live updates
- [x] 1.3 MCP server (Edge Function `docs-mcp`), tokens, audit log, kill switch, Gemini path token tested
- [x] 1.4 AI space: Review inbox, diffs, risk flags, side panel, undo; Trash with timer (default: keep until deleted by hand)
- [x] 1.5 CI (GitHub Actions) with browser tests; Vercel deploy
- [x] 1.6 Organizations > Projects, roles, invitation links, RLS matrix, project switcher

PHASE 2: Workspace UI v2 (DONE 2026-10-21; polish list below)

- [x] 2.1 Start address = Organizations page (cards/list, search, role filter, sort, create/rename/delete/restore)
- [x] 2.2 Soft delete for organizations (delete_org, restore_org, purge_org; Deleted tab; typed name; Undo)
- [x] 2.3 Organization page: Projects / People / Invitations / Activity / Settings; archived projects restore or delete for good
- [x] 2.4 Invite always reachable (header button, project page, Ctrl+K, Invitations tab)
- [x] 2.5 Project home with all documents and the question bar
- [x] 2.6 Breadcrumbs app > organization > Projects > project > page with switchers
- [x] 2.7 Custom animated dropdowns replace every native select (docs/24: our Select already follows the APG select-only model; fix `aria-controls` id/role, decide Tab-commit; 2-day React Aria spike on this control and the palette, adopt only if it passes our animations, native dialog and a physical Android TalkBack test)
- [x] 2.8 Compact hover/click areas app-wide (one density rule set) (docs/24: 30 px rows are fine; every interactive hit area must be >= 24x24 CSS px or meet the spacing exception: Playwright geometry test)
- [x] 2.9 Sidebar groups (Project, Chapters, Pinned, Questions, Review, Manage); top level lists organizations and projects
- [x] 2.10 Account menu rebuilt (narrow, no search)
- [x] 2.11 One search (Ctrl+K) with scopes, prefixes `> # @`, recents, finds added pages (docs/24: dialog + editable combobox + listbox; scope filters are NOT tabs; Ctrl+K must not fire inside the editor or text fields)
- [x] 2.12 Header actions: search, review-inbox bell, pin, "…" menu (docs/24: bell name includes unread state in text; Realtime updates announced politely and aggregated, never moving focus)
- [x] 2.13 Sign-in card on the start page; invitation page asks to sign in first
- [x] 2.14 Invitation email (animated header GIF, CSS animation for Apple Mail/iOS/Samsung, works everywhere, plain-text part) + `/api/invite` + rate limit 20/hour 60/day per organization
- [x] 2.15 Tests for all of the above
- Polish (keep small; research says several of these are low value for a solo owner)
  - [ ] 2.16 S In-app "preview the email" button (sample exists at /email/invite-preview.html); invitation lifetime 72 h; `safeMailDisplayName` for the inviter name in the From display name (strip CR/LF/control characters, quotes, angle brackets; cap length); the message stays fully understandable with images off (headline, inviter, organization, expiry and button are real HTML text; the GIF is decoration; no tracking pixel)
  - [ ] 2.17 S Resend / re-create an invitation from the Invitations tab
  - [ ] 2.18 S Invitee sees pending invitations after sign-in **Q12**
  - [ ] 2.19 S Breadcrumb "…" overflow menu for hidden middle crumbs
  - [ ] 2.20 S Native `<dialog>` + `showModal()` for true modals (top layer, inert background, less home-made code); keep our custom select/menu/combobox (D13); Popover only where it removes light-dismiss code; keep tests for Tab, Escape, Enter, Space, arrows and focus return (docs/19) (docs/24 AGREE: already used in 5 dialogs; popups are portalled into the open dialog; never nest dialogs or portal to body from inside one; test select/menu inside a dialog in Chromium, Firefox, WebKit, iPhone and Android: visible AND interactive)
  - [ ] 2.20b S Palette: highlight matched letters, recent searches, Ctrl+Enter new tab
  - [ ] 2.21 S Favourites (table user+doc) at the top of lists; recents stay in localStorage (docs/18 #11)
  - [ ] 2.22 S Display name per person (lists show emails today)

    - [ ] 2.23 DEFERRED move project across organizations (export/import covers it)
    - [ ] 2.24 S Transfer ownership; explain "last owner cannot leave" in the UI
    - [ ] 2.25 DEFERRED keyboard chords; 2.27 a SMALL visual-regression set NOW (docs/24: 10-20 Playwright `toHaveScreenshot` shots on the CI OS: dropdown open/closed, dialog, palette, org page at 390 and 320 px, plan, review, forced-colors and reduced-motion; not a design-system suite); 2.28 DEFERRED logos/accents
    - [ ] 2.26 M Phone: bottom bar, test every page at 360 px (docs/24: also verify 320 CSS px reflow, not only 360 px; real iPhone + Android tests)
    - [ ] 2.29 M Notification inbox (see 3b.2)
    - [ ] 2.40 S **Route accessibility (docs/24)**: skip link to `<main>`; unique `document.title` per route; on a real route change move focus once to the new `h1` (`tabindex="-1"`) and never on filter/sort changes; no "page loaded" alert; keep history entries only for route-level navigation
    - [ ] 2.41 S **Route-backed tabs**: organization sections and the active/deleted switch become hash sub-routes (`#/org/<id>/people`) rendered as links with `aria-current="page"` and tab styling; today they are `role=tab` buttons with no arrow keys, tabindex or panels (**Q30**)
    - [ ] 2.42 S **Control-border token**: text inputs, textareas and search fields need a border at >= 3:1 (candidate `--ctl-line: #77756c`, check on `--hover`/`--active`); `--line`/`--line2` stay for decoration; a CI script parses the CSS tokens and asserts the contrast ratios
    - [ ] 2.43 S Global `forced-colors` pass (borders/outlines instead of shadows for state, selected rows, focus ring); text-spacing and 400% zoom checks
    - [ ] 2.44 S Playwright geometry test: fail any visible interactive element under 24x24 CSS px without the spacing exception
    - [ ] 2.45 S Accessibility statement (WCAG 2.2 AA target, tested browser/AT combinations with dates, known limits: editor and merge view until proven) + issue template that forbids private content and tokens
    - [ ] 2.46 M **Keyboard and AT release gate** (docs/24 checklist): NVDA (Chrome), Narrator, Android TalkBack, iPhone VoiceOver on select, palette, dialog, plan, editor, diff, auth; recorded with date and version (**Q32**)
- Owner checks (OWN)
    - [?] 2.30 Real two-account invitation test (Invite > link > private window > sign in as that address > Accept)
    - [?] 2.31 Turn on email sending (section 13)

PHASE 3: Private by default and sharing (P5-V) — do before any new table work

D1: only signed-in users see docs; public only through deliberate share links.

- [ ] 3.0 S **Grants rule + 10-30 migration (do first, this week)**: opt in now with `alter default privileges for role postgres in schema public revoke select,insert,update,delete on tables from anon,authenticated,service_role;` + the same for functions (`revoke execute`, also `from public`) and sequences (`revoke usage,select`); every new table AND function gets explicit GRANT/EXECUTE + RLS + policies + indexes in the same migration; revoke the unneeded anon SELECT on `workbench_state`, `app_admins`, `project_members`; the matrix asserts `has_table_privilege('anon', t, 'select')` and `has_function_privilege('anon', f, 'execute')` are false on private objects. Also: classify the 28 `SECURITY DEFINER` functions (keep / switch to

invoker / revoke / move to `private`), set `search_path=''`, qualify `extensions.digest`. Lands before 2026-10-30 (docs/16, docs/19).

- [ ] 3.1 M `get_content_bundle` requires a signed-in member (or a valid share link)
- [ ] 3.2 S Sign-in as the first screen (the start page already shows a card; the spec is still reachable by address until this step)
- [ ] 3.3 M MCP: anonymous tools return nothing; every AI client uses a token
- [ ] 3.4 S Project `geminiforge` set to `private`; check every table, RPC and MCP tool as `anon` (RLS behaviour AND grants)
- [ ] 3.5 M **Share links (audit, docs/21)**: table `share_links` (project-wide per D14; several independent labelled links; read-only; default expiry 7 days, no never-expire; `secret_hash` = SHA-256 of 32 random bytes, raw secret shown once; revoked_at; last_viewed_at; view_count; no raw IP). Redemption through a SERVER proxy (3.11), NOT an anonymous RPC and NOT a share JWT; the SQL function is executable only by service_role and hashes with `extensions.digest`. Public projection allowlist: project name/description; documents (opaque key, title, current body, order); plan (title, hierarchy, status). EXCLUDED: members, emails, user ids, revisions, review inbox, drafts, Trash, comments, tokens, audit, notifications, search tables, Storage, Realtime, exports, restricted documents (Q22). No Storage images in v1 shares
- [ ] 3.6 S Who may make a project public/unlisted: only organization owners/admins **Q1**
- [ ] 3.7 M Tests: anon gets nothing; share link works until revoked or expired; drafts, Trash, exports, search and comments are not readable by outsiders (BookStack lesson, docs/18)
- [ ] 3.8 S RLS rules: `(select auth.uid())`, `to authenticated` on every policy, index every policy column, no `user_metadata`, `security_invoker` views; run advisors after each migration and fail CI on ERROR (docs/16)
- [ ] 3.9 Confirm with the owner before switching (the site stops working for signed-out visitors) **Q3**
- [ ] 3.10 S **Share route** `https://<app>/share#<secret>` (replaces `/#/s/<secret>`): Vercel rewrite `/share` to index.html, hash router also reads `location.pathname`; the first paint shows nothing; an explicit "Open shared project" click POSTs the secret in the body; then `history.replaceState(null,'','/share')`; content stays in memory only (no LocalStorage/IndexedDB/Cache/service worker); no analytics or third-party requests; external links `rel="noopener noreferrer"`; reload after cleanup asks to reopen the link (docs/21)
- [ ] 3.11 M **Share proxy** `api/share.ts` on Vercel (secret key only in a server env var, never `VITE_*`): validate method/Origin/body size/token format, check the global kill switch, rate bucket (pseudonymous, short-lived, no raw IP), then hash + lookup + projection; generic denial text; `Cache-Control: no-store`; revocation checked on every fetch; counters only (view_count, last_viewed_at)
- [ ] 3.12 S **Kill switch** table `private.security_settings(public_sharing_enabled, invitation_sending_enabled)` + owner-only AAL2 actions "disable public sharing" and "revoke all share links"; tested before sharing ships
- [ ] 3.13 M **Invite-bound account creation** (the app has no way to create an account today): public sign-up OFF in the dashboard; `#/join/<token>` GET does nothing; existing account must sign in first; new account: password (minimum 15) + Cloudflare Turnstile + click "Create account and join" POSTs to `api/join`, which validates the invite and calls `auth.admin.createUser(email_confirm:true)` with a server key, inserts membership, consumes the invite, handles partial failure (reconcile record), returns generic errors, never logs bodies. Note: password-reset mail still uses Supabase's default SMTP (best-effort, rate limited): decide Gmail custom SMTP in Supabase Auth (Q25)
- [ ] 3.14 S **TOTP for owner/admin** (Q23) and `aal2` checked INSIDE the sensitive RPCs and policies (share create/revoke, role changes, export, delete project/user, invite send, kill switch); enrol a BACKUP factor and

rehearse recovery on a throwaway account before enforcing; Supabase does not return recovery codes for its own accounts (project-user recovery codes UNVERIFIED)

- [ ] 3.15 S **Harden** `api/invite`: authenticated + AAL2 + org owner/admin checked server-side + an existing unexpired invite row; recipient, subject and body derived server-side (never from the request); quotas 3/hour and 10/day per organization and 3/day per recipient (policy choice, replaces 20/60); generic failure text, no SMTP diagnostics to the browser
- [ ] 3.16 S **Privacy**: delete the duplicate invitee email once the invite is accepted/expired and reconciled (a hash is still personal data); invitation preview shows nothing to unauthenticated visitors; members see names and roles, emails only where needed; deleting a user pseudonymises author ids in revisions instead of cascading; finite retention for security events
- [ ] 3.17 M `private.security_audit_log` append-only (no grants to API roles; trigger rejects UPDATE/DELETE; typed insert helper with a metadata allowlist): role/membership changes, invite create/accept/revoke, share create/revoke/redeem/denial thresholds, export, destructive actions, AAL2 denials, kill-switch use. Never log passwords, raw tokens, secret keys, bodies, headers, raw IPs. Tamper-resistant, not DBA-proof; hash chain only if it becomes important; pgaudit only for investigations. Reuse `membership_events`/`token_events` where they already fit
- [ ] 3.18 S **Incident runbook** (docs, before sharing ships): credential inventory and where each is used; rotation for `sb_secret_`, Gmail app password, Vercel env; leaked share link / key / member account / GitHub / Vercel / Supabase / Google; order for a leaked secret: revoke, rotate, redeploy, inspect, clean history last
- Research: docs/16 (limits, grants), docs/18 (share-link ideas; leak case studies there are UNVERIFIED), docs/21 (audit of the ChatGPT security report)

PHASE 3b: Trust and health (new, from the benchmark)

- [ ] 3b.1 M **Verified pages**: owner_id, verified_by, verified_at, verified_until, review_every_days, reviewed_rev; badge, filter, "changed since verified" diff; an AI-accepted edit does NOT renew the review; **AUDIT CHANGE (docs/19)**: store verification as immutable events `doc_verifications(doc_id, rev, verified_by, verified_at, review_after, note)` tied to our `doc_revisions.rev` and derive the state (unverified / changed since verified / review due / verified), no mutable flag; any later edit flips to "changed since verified"; no bare "still accurate" button (docs/13, docs/18 #1)
- [ ] 3b.2 M **Notifications** table (AI edit waiting, verification due, mention, role change, request access) over Realtime; the bell shows it; no email digest (Q10)
- [ ] 3b.3 S Daily job (pg_cron) only inserts reminder notifications (expiry is derived from `review_after < current_date`, never flipped) (max 8 jobs, each under 10 minutes)
- [ ] 3b.4 S **Request access** button + a `restricted` boolean per document (editors/managers only) instead of full per-page permissions **Decision D15:** a project-wide share shows every non-restricted document; restricted documents never appear in shares
- [ ] 3b.5 S Page views: `doc_view_daily(doc_id, day, count)` upsert RPC (no per-view rows); 30-day views, last viewed, "unread 90 days" staleness signal
- [ ] 3b.6 S In-app link check on save (`doc_links`: broken links, orphans, duplicate titles); markdownlint warnings only (MD001, MD024, MD051-053)
- [ ] 3b.7 S lychee on exported Markdown in CI on a schedule (not every push)
- [ ] 3b.8 S `revisions.actor_kind` (human | ai-token | import) with the token name; keep last N revisions plus every verified one; optional reason on delete
- [ ] 3b.9 S Content-gap list: log every question with no verbatim quote found, with a count; top ten on the dashboard (after phase 7) (docs/25: raw questions are private: owner-only, 90 days)

PHASE 4: Core product: master file, phases, steps, decisions (design in docs/13)

- [ ] 4.1 M Tables `plan_nodes` (adjacency list `parent_id`, `kind` phase|step, depth ≤ 4, fractional `position` text COLLATE "C", status todo|doing|done|blocked|cancelled|deferred, weight int default 1, rev, `on delete restrict`), `plan_edges` (blocked_by, cycle-rejecting trigger), `decisions` (MADR fields, never renumbered), `decision_links`; RLS inherits from `project_id` via our existing `private.can_read_project/can_edit_project`; GRANTs in the same migration (3.0). **AUDIT CHANGE (docs/19, Q20)**: prefer integer gap `order_key` (our `docs.position` is already integer) over fractional text (keep `COLLATE "C"` only if fractional stays); drop weights in v1 (equal leaf steps); do not put a plain unique index on the order key (reorders hit transient duplicates: deferrable constraint or two-step renumber); depth trigger as in the report
- [ ] 4.2 M Progress as a SQL view/RPC, never stored: only leaf steps count; cancelled/deferred leave the denominator; blocked stays and shows a red count with its reason; `doing` counts 0 (optional 25% toggle); empty container shows "no steps"; round down so 99.6% never shows 100%; show n/m, "+N steps added" (baseline when a phase starts), next step
- [ ] 4.3 M Master file view: auto-index of phases with progress; phase view with steps/sub-steps and check marks; dependencies ("waiting on D-0012") (docs/24: nested ordered lists + disclosure buttons + NATIVE checkboxes for leaf steps; NO tree/treegrid in v1; blocked/deferred/cancelled are visible text, never checkbox states; no `aria-checked=mixed` for computed progress; progress read as "8 of 12 countable steps complete; 2 blocked", optional `<progress>`)
- [ ] 4.4 M Decision log (MADR 4.0): proposed > accepted > deprecated | superseded | rejected; accepted records change only status and supersession; `[[D-0012]]` links; accepting offers to unblock linked steps; `review-by` feeds the stale list
- [ ] 4.5 S Templates: software, research, course, trip, "this master plan" (import via status-character map `x` done, ~ doing, `?` blocked "waiting on owner"); `is_template` flag + "New from template" copy, no variables yet
- [ ] 4.6 S List view only first; board, timeline and ICS DEFERRED
- [ ] 4.7 S Project dashboard: open steps, blocked steps, waiting AI edits, stale pages, content gaps
- [ ] 4.8 M AI proposals never write plan tables: ops `{set_status|move|insert|retitle|edit_notes, node_id, base_rev, value}` go to the Review inbox; accept only if `rev = base_rev` (else stale); AI creates decisions only as `proposed`; check marks are never auto-applied; moves validated for cycles and depth
- [ ] 4.9 S Q9 decide whether this master plan becomes the first project (template)

PHASE 5: Editor: owner edits everything (docs/17)

- [ ] 5.1 M **CodeMirror 6** Markdown editor with `react-markdown` preview (split or toggle); front matter via `remark-frontmatter`; math (KaTeX) and Mermaid lazy-loaded; sanitize after the last unsafe step; rules (docs/19): no raw HTML, never `dangerouslySetInnerHTML`, URL scheme allowlist, no remote images in the Review inbox, render search snippets as text with our own `<mark>`, Mermaid DEFERRED, KaTeX only after a sanitizer test; fix-up for `user-content-` id prefix in block anchors (docs/24: editor has an accessible name; document the Escape-then-Tab exit in keyboard help; line wrapping on; test forced colors and mobile)
- [ ] 5.2 M Save with a `version` column (`update … where version = base`); on conflict 3-way merge (`node-diff3`), remaining conflicts shown as a diff; keep BOTH versions on conflict; Supabase Presence only for a soft "X is editing" banner; no offline writes in v1

- [ ] 5.3 L Edit generated spec pages and chapters; migrate derived spec documents to native documents (docs/01 step 6)
- [ ] 5.4 M Add / remove / move / rename chapters and sections; drag-and-drop order (fractional keys) (docs/24: WCAG 2.5.7: ship Move up / Move down / Move to in each item menu together with drag)
- [ ] 5.5 M Revision compare of any two versions (`diff` jsdiff 9); restore one paragraph
- [ ] 5.6 M Internal links `[[kind:slug]]` (small micromark/remark plugin, keyed on ids), backlinks panel
- [ ] 5.7 M Per-hunk accept in the Review inbox with `@codemirror/merge` (`unifiedMergeView`, `acceptChunk`/`rejectChunk`); human "suggest" edits from viewers also go through the inbox; comments carry an anchor quote + resolved flag, no threads yet (docs/24: keep the visual merge view but add a linear "Changes" list: hunk n of m, old/new text, native Accept/Reject buttons with context names; focus moves to the next hunk; not claimed accessible until a real AT session proves it)
- [ ] 5.8 M Import/export (docs/21): Markdown zip in and out FIRST, parsed in a Worker (`@zip.js/zip.js` 2.24.0 preferred for hostile input, fflate 0.8.3 acceptable, version pinned) with hard caps (25 MiB archive, 100 MiB emitted bytes counted while decompressing, 10 MiB per entry, 1000 entries, ratio 100:1, depth 20, filename 240) and rejection of symlinks, absolute/drive/UNC paths, `..`, NUL, Windows reserved names, case/normalisation collisions, nested archives; front matter: known scalar keys only, no custom tags/aliases, reject `__proto__`/`constructor`/`prototype`; CSV export neutralises `= + - @`; SVG upload rejected; EXIF/GPS stripped by re-encoding if images ever import. DEFERRED: `.docx` (when added: Mammoth latest, Worker, external file access off, advisories rechecked), Notion zip, Obsidian vaults (ignore `.obsidian`). Test corpus = M01-M37 in docs/21a; keep zip export working at all times
- [ ] 5.9 S Images only (Supabase 1 GB bucket, 50 MB file cap); other attachments DEFERRED
- [ ] 5.10 DEFERRED Tiptap block editor (ship later behind a round-trip gate: parse > serialize > compare, else source mode), inline live-preview decorations, CRDT (Yjs/Hocuspocus/Liveblocks/Automerge), Mermaid sandbox, PDF export (use print CSS)

PHASE 6: AI space v2 and token safety (docs/14) — re-ordered

- [ ] 6.1 S **Verify the MCP with Claude Code, Cursor, claude.ai connectors and the Gemini app FIRST** (only Gemini is tested today) **Q5**; then make `header` the default token kind and `path` the exception (docs/25: test Gemini and a free Claude account first: Claude Free allows ONE custom connector and supports fixed header tokens; **ChatGPT (OpenAI doc developers.openai.com/api/docs/guides/custom-mcp-server, verified 2026-10-22): add a custom MCP server by name + Server URL (or Tunnel) in ChatGPT on the web; authentication = OAuth, No authentication, or OAuth-or-no-authentication (mixed: initialize and tools/list without auth, tools by their security schemes; OAuth can use CIMD or DCR); NO API-key/header option, so ChatGPT can only reach our server with a path token (No authentication), the same exception as Gemini; supported protocols SSE and streaming HTTP; write actions are allowed but ask for confirmation unless a tool has** `readOnlyHint` **(ours do);** `search`/`fetch` **tools are not required; the first 512 characters of the MCP** `instructions` **should be self-contained (ours are 444); workspace Lockdown rules apply; the page lists no plan eligibility, but the owner's Plus account shows the dialog (screenshot), so the report's "Plus is not eligible" was wrong here; untested against our server (Q39)**; Cursor/Windsurf free eligibility UNVERIFIED; Gemini CLI consumer entitlement ended 2026-06-18)
- [ ] 6.2 S **Sanitise the Review inbox**: no remote images, link targets shown as text, diffs as plain text (exfiltration through rendering; Notion AI lesson)
- [ ] 6.3 S Token display: a digest-derived FINGERPRINT (first 8 hex of SHA-256 of the token, shown with client, kind and time left) instead of "last 4 of a checksum suffix" (a suffix checksum is predictable). Tokens

today are `dk_` + 64 hex (256 bits); a `gfk_` prefix + checksum is optional and only for secret-scanner recognition; gitleaks rule for `dk_[0-9a-f]{64}` in CI (docs/25)

- [ ] 6.4 M Two token kinds, path tokens read-only with 24 h default expiry, one per client, revoked on rotation; rotation with overlap (docs/25 evidence; Gemini AND ChatGPT can only use path tokens, so keep them read-only, 24 h, one per client: all 47 `function_edge_logs` rows of the last 24 h contain a `/dk_` path segment, i.e. path tokens are stored in Supabase function logs (Free log retention is short); test Google's "Advanced features" credential path and Claude header tokens; keep path tokens only for the Gemini exception; never use one as an OAuth access token or forward it)
- [ ] 6.5 M Per-token tool and document allow-lists; static tool descriptions; expose a hash of the tool list; token templates (Reader, Typo fixer, Writer) (docs/25: the hash covers canonical tool names, input/output schemas and descriptions; publish it in `get_guide`, compare with the release manifest in CI, alert on mismatch; tool descriptions stay static code, never built from document text or owner messages; annotations are hints, never authorization)
- [ ] 6.6 S Per-token usage panel (last used, call count, documents touched, from the audit log); MCP tool `report_issue(doc, text)` lands in the Review inbox
- [ ] 6.7 M Review friction: a reason is required to accept high-risk drafts, no bulk accept for them; auto-accept only a narrow class (typo fixes by a named token template), off by default
- [ ] 6.8 M Data protection: purge or hash invitee email after accept/expiry, per-person export and delete, log retention period, no tokens or IPs in logs
- [ ] 6.9 S Append-only audit log + CSV export. The weekly "head hash" e-mail is DROPPED (docs/25: no tamper evidence without a hash chain; revisit only if a chain/checkpoint model is built)
- [ ] 6.10 S Keep the kill switch and per-token limits; anomaly alerts and auto-pause only if cheap
- [ ] 6.11 M OAuth stage ONLY if 6.1 shows a client needs it: Supabase OAuth 2.1 server is a public beta with full-privilege user tokens; needs DCR enabled, a consent page (client name, exact redirect URI, CSRF, anti-framing), RESTRICTIVE RLS for `client_id IS NOT NULL`, an access-token hook setting/checking `aud`, 401 + `resource_metadata` from the Edge Function, manual tokens kept as fallback
- [x] 6.12 Support MCP spec 2026-07-28: DONE (docs/25 audit of our code): `@modelcontextprotocol/server` 2.3.1 `createMcpHandler`, stateless, `server/discover`, `ttlMs`/`cacheScope` hints, legacy 2025-06-18 `initialize` still answers (test), GET gives 405. Left: tests for `UnsupportedProtocolVersionError`, `HeaderMismatch` (-32020) and the Origin rule (6.14); sampling, roots, logging, elicitation, Tasks, MCP Apps stay unused
- [ ] 6.13 S Per-project retention of activity and AI policy
- [ ] 6.14 S **Origin and Host validation (docs/25; MCP spec MUST: "if the Origin header is present and invalid respond 403")**: today `makeFetch` answers every request with `Access-Control-Allow-Origin: *` and never checks Origin. Use the SDK helpers `originValidationResponse` / `hostHeaderValidationResponse` (allowlist empty by default; a browser-based MCP Inspector origin only in test), accept requests with no Origin (server-to-server hosts), expected function hostname for Host, remove the wildcard CORS unless an origin is allow-listed, reject JSON-RPC batch arrays, keep GET/DELETE at 405 (**Q36**)
- [ ] 6.15 S **IP pseudonym**: `ipOf` is SHA-256 of a fixed public string + IP cut to 64 bits: reversible by enumerating IPv4. Use HMAC with a secret from the function environment (rotated), or store nothing (plan 6.8)
- [ ] 6.16 M **MCP security test pack (docs/25)**: planted `IGNORE ALL PREVIOUS INSTRUCTIONS` and fake system prompt documents; remote-image and `javascript:` links in pending Markdown cause zero requests/execution; invisible Unicode; token for project A asking for B (no existence leak); reader token calling a proposal tool; revoked, expired and query-string tokens; wrong Host / hostile Origin; batch array;

oversized body/query; stale `base_rev`; cursor reuse; kill switch mid-sequence; tool-name collision and manifest-hash mismatch; raw tokens never in our own logs; run on every MCP change (merge into the 70-item security pack)

- [ ] 6.17 S **Risk classes in the Review inbox (extends 6.7)**: Low (spelling, whitespace, punctuation outside code/identifiers), Medium (prose rewrite, headings, link changes), High (auth, permissions, privacy, RLS, sharing, secrets, token lifetimes, commands, SQL/migrations, deletion, check marks: reason required, no bulk accept), Blocked-from-auto-accept (plan completion, destructive operations, access control, external URLs, security policy, flagged injection); per-hunk decisions and ids live in our tables, not in CodeMirror; accept re-checks `current_rev = base_rev`; metrics: post-accept undo rate, reversal within 7 days, high-risk rejection rate, stale-proposal rate, review time, queue age, accept/reject per token
- DEFERRED: two-person approval; GitHub secret-scanning partner programme

PHASE 7: Ask-the-docs at zero cost (docs/15, constraint D11)

- [ ] 7.1 S **Free path 1: Gemini app + our MCP** (owner-accepted CONSUMER-CLOUD path: retrieved text goes to Google's consumer service, label it in the UI, **Q38**). Google's help (verified 2026-10-22): 18+, US, personal Google account, Keep Activity on, English only, add it in the Gemini WEB app (works on mobile afterwards), standard MCP server URL, writes need manual confirmation; if the server has no DCR use "Show more" under "Advanced features" for credentials; NO subscription (AI Pro) requirement is stated. Record account type, region, app date and test date after every successful test (docs say US-only, ours already works). Edits still go through the Review inbox (docs/25)
- [ ] 7.2 S **Free path 2: NotebookLM ("Gemini Notebook")** as a personal reading aid: free 50 sources per notebook; merge pages into ≤ 50 files (export from the app). It cannot be called from our app. (docs/25: exact current source limits UNVERIFIED; manual export only, no sync around an undocumented API)
- [ ] 7.3 M **Extractive quote-finder (no model) = PRIMARY in-app Q&A (docs/25):** `doc_chunks` is a derived index of `docs.body` (never rewrite whitespace): H1-H3 sections, ancestor heading path searchable, paragraph-boundary splits by a CHARACTER cap (no tokenizer dependency), exact start/end offsets into the current body, weighted `tsvector` (title/heading high, body normal) + GIN, queried under the caller's project authorization. TWO lanes: FTS (`websearch_to_tsquery`) and a literal-substring lane for identifiers, versions, paths, quoted phrases (optional `pg_trgm` later). Rank: title > heading > body rank > small verified boost > chunk-id tie-break. The answer is the best passages shown verbatim with Document > Heading > revision > verified date. No API, no key, no cost
- [ ] 7.4 S Content-gap log: every question with no passage found, with a count (feeds the dashboard) (docs/25: raw questions are private data: owner-only table, 90-day retention unless promoted to a task, **Q37**)
- [ ] 7.5 M **40-question golden set (FIXED: the old split summed to 42)**: 22 single-document facts (8 exact identifiers/numbers; gold chunk in top 6 for >= 21/22), 6 cross-document (every needed document in the top set for >= 5/6), 4 paraphrase (>= 3/4), 6 unanswerable (6/6 refuse), 2 adversarial/injection (evidence found, injected instruction ignored); quote validity 100%. Record recall@6, exact-quote validity, multi-document completeness, refusal and false-refusal rate, answer correctness where synthesis exists, latency p50/p95, source-revision correctness; individual failures stay visible (40 cases are too few for percentage claims). Embeddings only if more than about 2 of the 34 answerable/adversarial cases still miss or the paraphrase slice keeps failing
- [ ] 7.6 S Trust boost: verified pages rank higher; mark results verified/unverified
- [ ] 7.7 DECISION (docs/25): optional generative answers at 0 cost. NO private text to any free API: Gemini API unpaid tier = Google uses content to improve products, human reviewers may read it, do not submit sensitive data; Mistral Free mode may train on inputs (opt-out exists); OpenRouter `:free` = 20 requests/min and 50/day (1,000/day only after buying credits = against D11), provider handling not uniformly verifiable;

Cloudflare Workers AI 10,000 neurons/day (data-use terms UNVERIFIED); Groq/Cerebras/Hugging Face limits UNVERIFIED (not needed). Only private-safe generative route = in-browser model: WebLLM 0.2.86 (Apache-2.0, multi-GB download, desktop only, Android Qualcomm failures reported), Transformers.js 4.3.1 (embeddings/classification), Chrome built-in AI (desktop-class hardware only): experimental opt-in button after 7.3-7.8, never automatic. Whatever answers: no tools, plain-text rendering, quote verified by 7.8, no benchmark numbers invented

- [ ] 7.8 M **Quote verifier and source panel (docs/25)**: pipeline retrieve -> model proposes claim + chunk id + candidate quote -> server locates it (exact substring first; Unicode/whitespace/quote/dash normalisation ONLY to locate, with an index map back) -> UI shows `docs.body[start:end]` of the stored revision, never the model's copy. Three checks: existence, attribution (from those offsets), support (not deterministic: golden set + human review). REMOVE the 6-word minimum ("24 hours", "PostgreSQL 17.11" must pass), keep a maximum (about 80 words). Every claim gets a source chip that opens Document > Heading > revision > verification state > highlighted plain-text quote; fabricated, wrong-revision and misleading-but-real planted quotes are tests (Q-01..Q-06)
- [ ] 7.9 S Sanitise every untrusted surface, not only Review: Q&A previews, notifications, source cards and diffs render plain text; no remote images; link targets shown as text and opened only by deliberate click
- NOT used (costs money or breaks terms): Anthropic/OpenAI/paid Gemini, rotating several free accounts.

PHASE 8: Reader and search

- [ ] 8.1 M Stable block anchors + copy link; search filter chips (project, kind, verified, owner, labels); keyword search only until the 40-question set fails
- [ ] 8.2 S Reading position memory, changed-since-I-read markers
- [ ] 8.3 M Offline READ cache only: vite-plugin-pwa precaches the app shell; allow-listed pinned documents in IndexedDB (Dexie); on sign-out delete IndexedDB, caches and the service worker; do not cache API responses; test Safari's 7-day rule on your phone (docs/24 REFINED: opt-in "Available offline on this device" pins only, read-only; the shell service worker stays registered (vite-plugin-pwa 2.0.0 / Workbox 7.4.1); delete the private IndexedDB on sign-out; "Forget this device" also unregisters; reauthorize before refreshing a pinned doc; never runtime-cache authenticated responses; no WebCrypto encryption of IndexedDB in v1; no offline edits, no Background Sync; Safari storage eviction: test on the real iPhone after 8+ days idle (UNVERIFIED))
- [ ] 8.4 DEFERRED semantic search, listen, focus mode, split view
- [ ] 8.5 S Single-key shortcut toggle (WCAG 2.1.4), contrast controls

PHASE 9: Operations, quality, survival (docs/16)

- [x] 9.1 CI runs typecheck, build, browser suites, MCP offline tests (docs/24 TODO: Vitest 5.0.5 for unit tests, Oxlint 9.16, ARIA snapshots, axe, pgTAP; Chromium on PRs, Firefox/WebKit nightly; Playwright traces on first retry; a retry-success is recorded as flaky with an issue and an expiry; PR CI under 10 min)
- [ ] 9.2 S **Keep-alive (docs/22)**: migration `public.ops_keepalive` (one row, explicit `GRANT SELECT` to anon/authenticated, RLS policy `id = 1`, no writes, not in the Realtime publication); two independent daily readers through PostgREST: Vercel cron `/api/ops-keepalive` (Hobby: once a day, runs anywhere inside the hour, +-59 min) and a GitHub Actions schedule at another hour (public-repo schedules self-disable after 60 days without repo activity). Reuse the env lookups `api/invite.ts` already uses. Each pings its own Healthchecks check on success and `/fail` on error (grace at least 2 h). Reading through PostgREST is the best-supported way to count as "user database activity"; `pg_cron`/Auth-only/no-DB calls are NOT relied on.

Route the Supabase pause-warning email to a mailbox you read. Restore window after a pause is 1 year (live page; the MCP docs index still says 90 days)

- [ ] 9.3 M **Backups (rewritten 2026-10-22, audited docs/22)**: Free has no managed backups (verified). Nightly Actions job: `supabase/setup-cli` (pinned SHA + pinned CLI version, no global npm install, no checkout), `SUPABASE_DB_URL` = **session pooler** string (the direct host is IPv6 only), three dumps (`--role-only`, schema, `--use-copy --data-only`), fail if empty, a manifest of row counts, **restore into a Supabase-shaped target in the same job** (local `supabase start` or vanilla Postgres 17 plus a prelude for roles anon/authenticated/service_role, schema auth and extensions; plain `postgres:17` alone fails; choose after inspecting the first real dump) with `psql --single-transaction -v ON_ERROR_STOP=1` and `session_replication_role = replica`; then `age` encrypt to the PUBLIC recipient (repo variable; private identity offline in two physical copies, never in GitHub); upload ciphertext only (artifact retention 14 d) and copy ciphertext to Backblaze B2 (10 GB free; rclone from the distro package, not `curl | bash`; app key limited to one bucket; Environment secrets limited to `main`); ping Healthchecks (`/start`, success, `/fail`). One daily cron; the weekly drill is decided inside the job by weekday (the report's `github.event.schedule == ...` test never fires). Separate Storage exporter with SHA-256 manifest, encrypted too. Monthly: owner downloads one object from B2, decrypts offline, restores locally. Exports are not one atomic snapshot (accepted). Nothing unencrypted is ever uploaded (public repo, D17)
- [ ] 9.4 S **Headers (docs/21)**: first move the inline CSS string (`parts/20-styles.tsx`) and the `<style>` in index.html into a real Vite CSS file; remove Google Fonts (system stack or self-hosted); then `vercel.json`: rewrite `/share`; CSP first as `Content-Security-Policy-Report-Only` (default-src 'none'; script-src 'self'; style-src 'self'; img-src 'self' blob: + our Supabase host; font-src 'self'; connect-src 'self' + Supabase https and wss; worker-src 'self' (add blob: only if the ZIP worker needs it); frame-src/media-src/object-src 'none'; base-uri 'none'; form-action 'self'; frame-ancestors 'none'; Trusted Types report-only later), global `Referrer-Policy: no-referrer`, `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Permissions-Policy` (camera/microphone/geolocation/payment/usb off), `Cross-Origin-Opener-Policy`/`Cross-Origin-Resource-Policy: same-origin`, global `X-Robots-Tag: noindex, nofollow, noarchive`, `/share` `Cache-Control: no-store`, `/assets/*` immutable one year. Do NOT set HSTS (Vercel already sends `max-age=63072000; includeSubDomains; preload`). No public CSP-report endpoint in v1 (catch violations in Playwright); enforce after the browser suite is clean. Vercel Hobby protects only preview/deployment URLs, not production (docs; a report claiming otherwise is unconfirmed)
- [ ] 9.5 S **CI and supply chain (docs/21)**: `permissions: contents: read`; every third-party action pinned by full commit SHA; never `pull_request_target` with untrusted code; no production secrets in PR jobs or in the dependency-install/build step; gitleaks (custom rules for `sb_secret_`, `GMAIL_APP_PASSWORD`, legacy service key) + osv-scanner + `npm audit --omit=dev --audit-level=high`; `npm ci` always; Dependabot (npm + github-actions, weekly, with cooldown, no auto-merge); npm `min-release-age=7` (npm >= 11.10); try `npm ci --ignore-scripts` and list which packages need scripts; GitHub settings: secret scanning + push protection, Dependabot alerts/updates, code scanning (check availability on a free account), private vulnerability reporting, a ruleset requiring CI on `main`; full-history secret scan DONE 2026-10-22 (53 commits clean); root accounts (GitHub, Vercel, Supabase, Google): unique password, strongest MFA offered, offline recovery material, few tokens; Playwright artifacts 7 days, traces only on failure
- [ ] 9.6 S Edge Function + migrations deployed from CI (scoped token, `supabase/setup-cli`, `db push --dry-run` first)
- [ ] 9.7 M pgTAP (`supabase test db`) next to the live DO-block matrix; axe in CI via @axe-core/playwright (wcag2a/aa, 21a/aa) (docs/24: axe finds about 57% on average, so pair it with keyboard scripts, ARIA snapshots and the physical-device AT matrix; pin the axe version; run axe at every widget state)
- [ ] 9.8 S **Monitoring (docs/22)**: UptimeRobot Free (50 monitors, 5 min; site + `/api/health`, which reads one row) and Healthchecks.io Hobbyist (20 checks: keep-alive x2, backup, storage export, restore drill, mail smoke test); alerts go to a personal address, not through the app's own mail; errors logged to a small table

(Vercel runtime logs last 1 hour on Hobby). Keep both on separate free accounts, one purpose each (Healthchecks forbids multiple accounts to dodge limits) **Client side (docs/24):** first-party `client_error_events` (release, route template, sanitized fingerprint, coarse browser; rate-limited, schema-validated, 30 days) and a `web-vitals` 6.2.3 RUM table (route template, release, metric, value, device class); never ids, titles, queries, hashes, emails, secrets. Vercel Speed Insights free tier gives only a Real Experience Score (10,000 events per rolling 30 days, then collection pauses at least 14 days): optional, not the source of Core Web Vitals. Sentry/GlitchTip on hold (free terms unverified)

- [ ] 9.9 S Legacy keys: browser, invite function and MCP already use `sb_publishable_`/`sb_secret_` (MCP still falls back to the legacy variable). Remaining: confirm in the dashboard, disable the legacy keys, remove the fallback, check `pg_net`/webhooks (secret key in the `apikey` header), audit Auth JWT signing keys (not the same project as API keys)
- [ ] 9.10 S Hobby is non-commercial: no payments/ads/paid hosting (check phase 11 ideas). No paid plans (D11): pausing is handled by 9.2, backups by 9.3; if a free tier is ever withdrawn, plan the export-and-move (Markdown zip + SQL dump) instead of paying
- [ ] 9.11 S Code-split the app (500 kB+ bundle warning), lazy-load labs and the answer engine (docs/24 budgets: initial JS <= 180 KiB compressed target / 220 hard, CSS <= 40, <= 30 requests, LCP 2.0 s, INP 150 ms, CLS 0.05 on a mid-range Android; split organization shell, project workspace, CodeMirror, merge, Markdown extras, import worker, labs, answer engine; never import test tools into production; virtualize only after measuring, about 300-500 rows is the first checkpoint; keep Vite's default target)
- [ ] 9.12 S **Canvas single-file build dropped (D12)**: tag the repo, then delete `canvas/`, `build-final.mjs`, `vite.final.config.ts`, `final/`, `index.final.html`, `App.final.tsx`, `main.final.tsx` and the Canvas tests
- [ ] 9.14 S React 19.3.1 (18.3.1 already in use as the stepping stone) + Vite 8.3.5; full Playwright suite green; NO React Compiler in the same change; View Transitions optional later
- [ ] 9.16 S **Lint (docs/24)**: our TypeScript is 7.0.2; `typescript-eslint` 8.72.0 supports only TypeScript <6.1 and `eslint-plugin-jsx-a11y` (last release 2024-10-26, ESLint <=9) is stale, so ESLint 10 + typescript-eslint is NOT usable now. Use **Oxlint** (MIT, 1.89.0; native TS/JSX; has jsx-a11y rules and react `exhaustive-deps`; `rules-of-hooks` opt-in) + `tsc` (TS 7) for types. Revisit ESLint when typescript-eslint supports TS 7.1 (TS 7.1 beta on npm 2026-10-20 adds the API; stable date unverified). Alternative: Biome 2.6.2 (rule coverage unverified)
- [ ] 9.17 S Engineering hygiene: `strict` plus `noUncheckedIndexedAccess` first, `exactOptionalPropertyTypes` later one flag at a time; error boundaries around editor, review and import; typed local feature flags with owner/date/removal condition; expand-migrate-contract for destructive migrations; one onboarding page (architecture map, commands, env var NAMES, migration and deploy procedure, keyboard contract, how not to leak data); Knip only after the `parts/` split (R0)
- [ ] 9.18 S **AGENTS.md rules for AI assistants (docs/24)**: one bounded change with acceptance tests, list affected files/tests first, small diffs, run typecheck/lint/unit/targeted Playwright at once, owner reviews security-sensitive SQL/API code, NO package installed until the owner verifies registry name, maintainer, age, licence and need (slopsquatting), no migrations/security policy/deploys without review, never put secrets, dumps, private documents, share links or production traces in prompts, update docs/ADR with the change (docs/25: keep it concise at the repository root; add a nested file only where rules truly differ)
- [ ] 9.15 S **Exit drill (docs/22)**: quarterly, restore the newest decrypted backup into a throwaway Neon Free project (1 GB per project, no card) and open the Markdown export. No $0 drop-in Supabase replacement exists (Auth, PostgREST, Realtime and Storage would have to be rebuilt); Neon is database-only. Netlify/Cloudflare Pages stay documented static-hosting exits, not set up
- [ ] 9.13 DEFERRED restructure R0 (folder layout) after features settle. Domain + Resend DROPPED (costs money): email stays on the free Gmail path

PHASE 10: Content corrections (after the app is finished, per owner)

- [ ] 10.1 Decide claims A1-A13 in docs/claims_ledger.md (or "apply all suggested actions")
- [ ] 10.2 Re-audit the GeminiForge documents; separate Gemini deep-research runs for that (not in docs/12)

PHASE 11: Optional (docs/05, pick later; each needs its own research; Hobby is non-commercial)

12. Cut or deferred (and why)

Two-person approval; hash-chain/replay audit; OAuth server (unless 6.1 proves a client needs it); pgvector; board/timeline/ICS; non-image attachments; move project across organizations; keyboard chords; visual-regression screenshots; logos/accents; domain + Resend; listen/focus/split view; four importers at once; backup encryption; CRDT; Tiptap block editor; offline writes; Notion link-graph reconstruction; PDF export; GitHub secret-scanning partner programme. Reasons: a solo owner on free tiers; most of these are Enterprise-tier features elsewhere (docs/18).

13. Turn on invitation email (OWN, about 5 minutes)

The website cannot send mail by itself. Supabase's built-in mail reaches only your own team's addresses (2 per hour); Resend's test sender reaches only your own address (docs/10, docs/16). `/api/invite` is deployed and already creates invitations; it emails as soon as it finds two settings.

1. Use a dedicated Gmail account; turn on 2-Step Verification. 2. Create an **app password** (Google Account > Security > App passwords; 16 letters). 3. Vercel dashboard > geminiforge-workbench > Settings > Environment Variables: `GMAIL_USER`, `GMAIL_APP_PASSWORD` (Production, sensitive); redeploy. 4. Open an organization > Invite; the checkbox "Email the invitation now" turns on. Never paste the password into chat or code. Limits: the app allows 3/hour and 10/day per organization and 3/day per recipient (policy, not Google limits; Google's exact personal-Gmail cap is UNVERIFIED, Workspace is 2,000/day). Gmail app passwords need 2-Step Verification that is NOT security-keys-only, no Advanced Protection, and are revoked when the Google password changes; SMTP `smtp.gmail.com:465` is UNVERIFIED from a Google page, so the first real send is the test. UNTESTED against a real mailbox until you add the settings. Edge Functions block ports 25/587 (465 is simply not documented as blocked), which is why the sender runs on Vercel; Supabase Auth custom SMTP is a separate service configured in the Auth dashboard (D18).

14. Questions for the owner (recommendation first)

- **Q1** Who may make a project public/unlisted? Only organization owners/admins.
- **Q2** May any signed-in user create an organization? No, only you for now.
- **Q3** When do we switch to "only signed-in users see docs"? Right after the first real two-account invitation test; note 3.0 (grants) lands before 2026-10-30 regardless.
- **Q4 (resolved, D12)** Canvas single-file build dropped.
- **Q5** Which AI clients besides Gemini matter (Claude Code, Cursor, claude.ai, ChatGPT)? This decides token kinds and OAuth (6.1).
- **Q6** Dark only? Yes (earlier decision).
- **Q7** Email: Gmail app password (free). A domain is out because of the $0 rule.
- **Q8 (resolved by research)** No key rotation. Q14 below replaces it.

- **Q9** Should this master plan become the first project in the app?
- **Q10** Notifications only inside the app (recommended) or also a daily email?
- **Q11 (recommend: skip)** Moving a project across organizations.
- **Q12** Show people their pending invitations after sign-in? Yes.
- **Q13** What does "Argon High" in your Gemini app refer to? Send a screenshot of the picker.
- **Q14 (replaced)** Ask-the-docs at $0: OK to start with Gemini app + MCP, NotebookLM and the extractive quote-finder, and decide generative answers after prompt Z1?
- **Q15** Turn on TOTP two-factor sign-in for your login (free per the docs, confirm in the dashboard)?
- **Q16** OK to add a daily keep-alive ping so the free project does not pause? (Supabase states no policy against it; paid plans are out.)
- **Q17** Do you want "verified pages" (owner + review date + badge)? Recommended: yes, it is the most valuable gap found.
- **Q18** Is a Markdown source editor with preview acceptable (not WYSIWYG)? Recommended; a block editor can come later.
- **Q20** Planning order key: integer gaps and equal-weight steps (recommended by the audit) instead of fractional text and weights?
- **Q21 (recommendation after docs/24: YES)** Minimum browser baseline: current and previous major of Chrome, Edge, Firefox, Safari incl. iOS; keep Vite's default build target (Chrome/Edge 111, Firefox 114, Safari 16.4).
- **Q22 (resolved, D15)** A project share shows every NON-restricted document and the share dialog says so.
- **Q23 (resolved, D16)** TOTP is mandatory for the owner, organization admins and project managers; everyone else is encouraged.
- **Q24 (resolved, D17)** The repo stays public while that helps; gitleaks runs in CI either way. Consequence: anything a workflow uploads (artifacts, logs) is downloadable by any signed-in GitHub user for 90 days by default, so NEVER upload unencrypted backups or data there.
- **Q25 (resolved, D18)** Gmail becomes Supabase Auth custom SMTP so password-reset mail is reliable (Supabase's custom-SMTP default is 30 new users/hour; `smtp.gmail.com:465` is UNVERIFIED from a Google page: prove it with one real send in a Preview, docs/22).
- **Q19 (replaced by Q27/Q28)** Backups: unencrypted private-repo artifacts are OUT (repo is public). Encrypted with `age` and copied to Backblaze B2.
- **Q26** Create a NEW dedicated Gmail for sending (authenticator-app or phone 2-Step Verification, NOT security-keys-only, no Advanced Protection; recovery info you control)? Recommended: yes (docs/22).
- **Q27** Try the Backblaze B2 sign-up now (email + probably a phone number; tell me if it asks for a card)? If it needs a card, fallback = 14-day encrypted artifact + a monthly manual download to your PC.
- **Q28** Keep two offline copies of the `age` private key (for example USB stick + paper, in different places)? Recommended: yes; without it every backup is unreadable.
- **Q29** Free Healthchecks.io and UptimeRobot accounts, one each, using the dedicated Gmail? Recommended: yes.
- **Q30** Make the organization tabs real routes (`#/org/<id>/people`)? Recommended: yes (2.41).
- **Q31** Run the 2-day React Aria spike on Select/Menu/ComboBox before deciding, or only fix our own widgets? Recommended: spike (a physical TalkBack test is needed either way).
- **Q32** Do you have an Android phone (TalkBack), a Windows PC (free NVDA and Narrator) and an iPhone (VoiceOver)? Without them screen-reader claims stay UNVERIFIED.
- **Q33** Offline: pinned read-only documents only (recommended) or nothing for now (8.3)?
- **Q34 (resolved 2026-10-22)** ChatGPT Plus shows "Add custom MCP server": custom connectors are possible on the owner's account.

- **Q39** Open the Authentication dropdown in ChatGPT's "Add custom MCP server" and list every option exactly (OAuth, No auth, the mixed option, any API key/header option); in ChatGPT's data controls check whether "improve the model for everyone" is on (retrieved document text goes to OpenAI like it goes to Google; label it, same as Q38).
- **Q35** Add our MCP as a custom connector in a free Claude account as the second test host (6.1)? Recommended: yes.
- **Q36** Add the Origin check (6.14, MCP spec MUST), accepting that browser-based tools such as the web MCP Inspector are blocked unless allow-listed? Recommended: yes.
- **Q37** Keep raw questions 90 days, owner-only, for the content-gap list (7.4)? Recommended: yes.
- **Q38** Accept and label that the Gemini app path sends retrieved document text to Google's consumer service (7.1)? Recommended: yes.

15. Decisions already made (do not re-ask)

D1 only signed-in users see docs, public only via share links. D2 **ENGLISH ONLY, ALWAYS** (UI, documents, prompts, research; owner said this repeatedly). D3 invited-only access: members see only invited projects; org owners/admins see all. D4 Trash default: keep until deleted by hand, timer per project. D5 multiple projects are a main feature; everything editable. D6 content corrections after the app is finished. D7 secrets never in chat/code/git; keys enter through dashboards. D8 free Supabase plan (no leaked-password protection). D9 daily research task deleted. D10 start address opens the Organizations page. **D11 (2026-10-21) spend nothing: free tiers only, no paid plans, APIs, domains or credits. D12 (2026-10-22) the Canvas single-file build is dropped. D13 (2026-10-22) keep our custom animated dropdowns (not native select). D14 (2026-10-22) share links are project-wide (read-only, expiring, revocable). D15** a project share shows all non-restricted documents. **D16** TOTP mandatory for owner, org admins, project managers. **D17** repo stays public (history clean; no unencrypted data in workflow artifacts). **D18** Gmail as Supabase Auth custom SMTP.

16. Research map

Done by Claude with sources: docs/10 (UI, email, Gemini, file hand-over), 13 (planning layer, decisions, health), 14 (MCP security, tokens, OAuth, review), 15 (ask-the-docs), 16 (Supabase/Vercel/GitHub limits, ops), 17 (editor, collaboration, offline, Markdown, import/export), 18 (workspace benchmark). Four big Gemini deep-research runs (technical foundations, AI-native docs, feature discovery, UX/visual design): docs/12. Their reports will be merged into this plan as docs/19-RESEARCH-RUN1..4. Also docs/19 (audit of the ChatGPT Parts A+B report, 2026-10-22; raw report docs/19a): corrections and live facts. Also docs/21 (audit of the ChatGPT Part C report, 2026-10-22; raw report docs/21a): verified facts, wrong claims, adopted design. Also docs/22 (audit of the ChatGPT Part E+F operations/email report, 2026-10-22; raw report docs/22a): verified platform limits, defects in the sample workflows, adopted keep-alive/backup/monitoring/email design. Also docs/24 (audit of the ChatGPT Parts D+G report, 2026-10-22; raw report docs/24a): verified standards and versions, defects (lint stack vs TypeScript 7, Speed Insights), audit of our own code, new steps 2.40-2.46 and 9.16-9.18. Also docs/25 (audit of the ChatGPT Run 6 AI/MCP report, 2026-10-22; raw report docs/25a): protocol facts verified against the 2026-07-28 spec, audit of our MCP function, live-log evidence, new steps 6.14-6.17 and 7.8-7.9. **Research status (2026-10-22):** DONE and audited: A+B (docs/19), C (docs/21), E+F (docs/22). DONE and audited: D+G (docs/24), Run 6 AI and MCP (docs/25). TO DO, prompts ready in docs/23 (ChatGPT Deep Research): Run 7 = feature discovery, Run 8 = UX and visual design. Owner rule: finish all research first, then plan. The Gemini prompts in docs/12 are superseded (Gemini froze at report writing three times).